

Laporan Lengkap — STIKOM Bali Pentest 2026

Anonymized version untuk portfolio publik. IP address, CSRF tokens, dan credential sample sudah di-redact.

Daftar Isi

1. Ringkasan Eksekutif
 2. Metodologi Pengujian
 3. Fase 1: Reconnaissance
 4. Fase 2: Subdomain Enumeration
 5. Fase 3: Origin Server Discovery
 6. Fase 4: Application Fingerprinting
 7. Fase 5: Vulnerability Assessment
 8. Ringkasan Temuan
 9. Rekomendasi Perbaikan
 10. Kesimpulan
 11. Lampiran
-

1. Ringkasan Eksekutif

Pengujian keamanan pada infrastruktur web ITB STIKOM Bali menemukan beberapa kerentanan serius yang memerlukan perhatian segera. Target utama (`sion.stikom-bali.ac.id`) dilindungi Cloudflare WAF, namun subdomain `pembayaran.stikom-bali.ac.id` **tidak diproteksi** dan mengekspos IP asli server origin.

Server origin menjalankan arsitektur hybrid (CodeIgniter untuk aplikasi utama, Laravel untuk panel admin/API). Ditemukan:

- **Origin IP Exposure** yang memungkinkan serangan langsung tanpa WAF
- **Tidak ada Rate Limiting** pada endpoint autentikasi (brute-force risk)
- **Debug Mode aktif** di produksi (stack trace disclosure)
- **Pesan error verbose** yang membocorkan struktur API
- **Web server kurang ketat** (folder internal accessible)

Dampak potensial: pengambilalihan akun admin, kebocoran data mahasiswa, serangan DDoS langsung, eksploitasi kerentanan lanjutan.

2. Metodologi Pengujian

Pendekatan: Black-box Testing dengan OWASP Testing Guide v4.

Prinsip etika: - Pengujian pasif dan non-destruktif - Tidak ada data yang dieksploitasi / diambil / dimodifikasi - Semua temuan dilaporkan ke pemilik sistem (IT STIKOM) - Responsible disclosure dengan timeline standar (90 hari)

Tools utama: - Nmap 7.98 (port scanning) - ffuf 2.1.0 (directory fuzzing) - curl 8.x (HTTP testing) - assetfinder, sublist3r (subdomain enum) - WhatWeb, Wafw00f (fingerprinting)

Detail lengkap: [tools.md](#) dan [methodology.md](#).

3. Fase 1: Reconnaissance

Target scan: `sion.stikom-bali.ac.id`

Hasil Nmap:

PORT	STATE	SERVICE	VERSION
80/tcp	open	http	Cloudflare http proxy
443/tcp	open	ssl/http	Cloudflare http proxy

Analisis: - Semua port dibalik **Cloudflare http proxy** - Header `server: cloudflare` mengonfirmasi WAF - SSL wildcard valid untuk `*.stikom-bali.ac.id` - `robots.txt` ada dengan `Disallow: /`

Kesimpulan: Target utama well-protected. Scan langsung tidak bisa identify OS, web server version, atau origin IP.

4. Fase 2: Subdomain Enumeration

Tool: assetfinder

Subdomain ditemukan (sample):

```
apision.stikom-bali.ac.id      (200)
apisiontest.stikom-bali.ac.id  (200)
pembayaran.stikom-bali.ac.id   (200) ← target investigasi
nms.stikom-bali.ac.id          (403)
absensi.stikom-bali.ac.id      (...)
alumni.stikom-bali.ac.id       (...)
```

Kesimpulan: Subdomain `pembayaran.stikom-bali.ac.id` aktif dan accessible. Fokus dialihkan ke sini.

5. Fase 3: Origin Server Discovery

Perintah:

```
curl -k -I https://pembayaran.stikom-bali.ac.id
```

Hasil:

```
HTTP/2 200
server: nginx
```

Temuan Kritis: Subdomain `pembayaran` **TIDAK melalui Cloudflare** — server respond langsung dengan `server: nginx`.

Nmap scan pada origin IP 103.148.xxx.xxx :

```
PORT      STATE      SERVICE      VERSION
22/tcp    filtered  ssh
80/tcp    open       http         nginx
443/tcp   open       ssl/https    nginx
3306/tcp  filtered  mysql
OS: Linux 4.X|5.X
```

Kesimpulan: IP origin (103.148.xxx.xxx) terekspos. SSH & MySQL filtered (good), tapi web services wide open tanpa WAF.

6. Fase 4: Application Fingerprinting

Directory fuzzing (ffuf):

```
admin      [Status: 301]
api        [Status: 301]
application [Status: 301]
```

Admin panel investigation: - URL: <https://pembayaran.stikom-bali.ac.id/admin/>
- Title: "Admin Sistem Pembayaran ITB STIKOM Bali" - Template: Lite-blue admin theme - Login form: email + password + CSRF token - Login endpoint: /admin/proses_login

Framework detection: - Root: **CodeIgniter** (cookie ci_session) - Admin panel & API: **Laravel** (error 419 Page Expired) - Hybrid architecture confirmed

7. Fase 5: Vulnerability Assessment

Detail per finding ada di folder [findings/](#):

#	Finding	Severity	CVSS 3.1	Status
1	Origin IP Exposure & WAF Bypass	 CRITICAL	7.5 (High)	Terbukti

#	Finding	Severity	CVSS 3.1	Status
2	Missing Rate Limiting on Login	 HIGH	7.5 (High)	Terbukti
3	Debug Mode Enabled (Stack Trace)	 HIGH	5.3 (Medium)	Terbukti
4	Verbose Error Messages	 MEDIUM	5.3 (Medium)	Terbukti
5	Misconfigured Web Server	 MEDIUM	5.3 (Medium)	Terbukti
6	User Enumeration via Forgot Password	 SAFE	—	Tidak rentan

8. Ringkasan Temuan

Detail ada di folder [findings/](#) — 1 file per finding dengan POC + CVSS + verification commands.

Finding	File	Severity	CVSS
Origin IP Exposure	01-origin-ip-exposure.md	 CRITICAL	7.5
Missing Rate Limiting	02-missing-rate-limiting.md	 HIGH	7.5
Debug Mode Enabled	03-debug-mode-enabled.md	 HIGH	5.3
Verbose Error Messages	04-verbose-error-messages.md	 MEDIUM	5.3
Misconfigured Web Server	05-misconfigured-web-server.md	 MEDIUM	5.3
Forgot Password (safe)	06-forgot-password-safe.md	 SAFE	—

9. Rekomendasi Perbaikan

Detail lengkap: [remediation.md](#).

Top 3 prioritas (SEGERA):

1. **Aktifkan WAF untuk semua subdomain**, terutama `pembayaran.stikom-bali.ac.id`
 2. **Implementasikan rate limiting** + CAPTCHA di semua endpoint autentikasi
 3. **Matikan debug mode** di produksi (`APP_DEBUG=false`)
-

10. Kesimpulan

Infrastruktur ITB STIKOM Bali secara umum well-protected di domain utama, namun subdomain kritis (`pembayaran`) terekspos tanpa WAF protection. Beberapa kerentanan serius memerlukan perbaikan segera.

Rekomendasi akhir: 1. Aktifkan WAF untuk SEMUA subdomain 2. Rate limiting + CAPTCHA di login 3. Disable debug mode di produksi 4. Audit keamanan berkala 5. Program responsible disclosure untuk menerima laporan dari eksternal

Lampiran

A. Timeline Pengujian

Lihat [disclosure-timeline.md](#) untuk timeline lengkap (uji → disclosure → patch → public release).

B. Verification Commands

Lihat [verification-commands.md](#) — commands yang IT team bisa run untuk verify setiap finding.

C. Anonymization Map

Data asli vs yang di-redact di repo publik ini:

Data	Asli (internal disclosure)	Repo publik ini
IP address	103.148.191.62	103.148.xxx.xxx
CSRF token	J70QpA2A00v0xpdweSFYyzfFfguiltvn21fYHtC1	<redacted-csrf-token>
Admin password (sample)	admin123	<redacted>
Server absolute path	/var/www/pembayaran.stikom-bali.ac.id/api/	<redacted-path>

 **Disclaimer:** Laporan ini disusun untuk tujuan edukasi dan responsible disclosure. Pengujian dilakukan secara etis, non-destruktif, dan tidak mengeksploitasi data apapun. Temuan harus segera dilaporkan ke pemilik sistem untuk perbaikan.